

Cyber Threat Intelligence

Executive Briefing

Report Date: July 06, 2026

Generated: 2026-07-06 01:50 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	9	6	1	20

2. Executive Summary

As of July 06, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as 4 Critical, 9 High, 6 Medium, and 1 Low. The current organizational risk posture is assessed as 'High' according to CVSS v3.1 standards, necessitating immediate remediation to prevent potential unauthorized system access. CVE-2026-49360, the Recce Server Unauthenticated SQL Execution Vulnerability, represents the primary threat due to the high probability of exploitation via unauthenticated remote vectors. Consequently, the enterprise is placed under an immediate mandatory patching posture, prioritizing all critical and high-severity assets to mitigate systemic exposure.

3. Critical Action List

- Execute immediate emergency patch deployment for CVE-2026-49360 on all Recce Server instances within 24 hours.
- Perform immediate configuration audit and cryptographic key rotation for all 9Router devices associated with CVE-2026-49352 within 24 hours.
- Isolate all LaunchServer environments and implement file path traversal mitigations for CVE-2026-54617 within 24 hours.
- Restrict access to Fast-MCP-Telegram services and deploy remediation for CVE-2026-52830 within 48 hours.
- Apply vendor-issued isolation bypass patches for Steeltoe Management interfaces (CVE-2026-50194) within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Recce Server Unauthenticated SQL ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	9Router Hardcoded JWT Secret Vuln...	9.8	Critical	88/100	CWE-798

CVE-2026-54617	LaunchServer Unauthenticated File...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Fast-MCP-Telegram Bearer Token Pa...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Steeltoe Management Port Isolatio...	8.2	High	74/100	CWE-288
CVE-2026-2092	Keycloak SAML Assertion Encryptio...	7.7	High	69/100	CWE-1287
CVE-2026-49353	9Router Host Header Spoofing Acce...	8.1	High	68/100	CWE-290
CVE-2026-46599	Golang Image PackBits Decompressi...	7.5	High	68/100	CWE-770
CVE-2026-50200	Steeltoe Env Sanitizer Password L...	7.5	High	68/100	CWE-200
CVE-2026-50196	Steeltoe Eureka Registry Poisonin...	7.5	High	68/100	CWE-20
CVE-2026-49289	SimpleSAMLphp XPath Transformatio...	7.5	High	68/100	CWE-400
CVE-2026-52829	Zebra Address Book Mempool Memory...	8.6	High	68/100	CWE-617
CVE-2026-52834	Jxl-Grid 32-bit Platform Integer ...	8.6	High	66/100	CWE-122
CVE-2026-49284	SimpleSAMLphp Improper SAML Respo...	6.1	Medium	64/100	CWE-345
CVE-2026-50201	Steeltoe Restricted Actuator Perm...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	Steeltoe Static JWKS Cache Invali...	5.9	Medium	53/100	CWE-668
CVE-2026-52792	Algernon NTFS Filename Script Sou...	5.3	Medium	48/100	CWE-69
CVE-2026-50267	Steeltoe TLS Private Key File Exp...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Kiwi TCMS Initialization Page Inf...	5.3	Medium	33/100	CWE-862
CVE-2026-50268	Steeltoe OAEP Padding Silently Do...	1.9	Low	17/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Recce Server Unauthenticated SQL Execution Vulnerability

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server component fails to sanitize input during database interactions, leading to unauthenticated SQL execution. This vulnerability stems from improper validation of input vectors passed to the underlying DuckDB engine. Attackers can leverage this to read or overwrite local system files, resulting in full compromise of data confidentiality and integrity.

Proof of Concept (PoC):

The attacker identifies an unauthenticated endpoint in the Recce server that accepts custom SQL queries. A malicious payload is injected into the request parameters targeting the DuckDB database driver. The backend processes the input without authentication, executing the injected commands with application privileges. This allows the attacker to read system files or perform unauthorized file writes to the local disk.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: 9Router Hardcoded JWT Secret Vulnerability

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

The 9Router application utilizes a hardcoded fallback JWT secret for signing session tokens. An attacker obtains this known secret through static analysis of the software distribution. Using this key, the attacker constructs and signs arbitrary JWTs with administrative claims. This allows full impersonation of any user, including administrative accounts, bypassing standard authentication.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: LaunchServer Unauthenticated File Path Traversal

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1083, T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

The FileServerHandler in LaunchServer incorrectly validates path parameters in HTTP GET/POST requests. An attacker sends a specially crafted request containing directory traversal sequences (e.g., ../) to access files outside the intended root directory. The server resolves these paths and returns the requested sensitive files. This compromise results in the disclosure of critical system or configuration files.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Fast-MCP-Telegram Bearer Token Path Traversal

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official
MITRE ATT&CK: T1083, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

No description available.

Proof of Concept (PoC):

The fast-mcp-telegram service contains a path traversal vulnerability in its bearer token management module. An attacker crafts a request containing directory traversal sequences to access and leak Telegram session tokens stored on the filesystem. The service fails to validate the token access path, allowing the attacker to bypass session protections. This leads to complete account takeover and remote service control.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Steeltoe Management Port Isolation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official
MITRE ATT&CK: T1557, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	Low

Confidentiality Impact	High
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

Steeltoe depends on Host header verification for management-port isolation, which is bypassable via header spoofing. An attacker presents an HTTP request with a modified Host header that matches the expected management interface mapping. The server allows the request to proceed, bypassing the network segmentation intended to isolate management traffic. This exposes administrative interfaces that should only be accessible on specific internal ports.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Keycloak SAML Assertion Encryption Validation Failure

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

No description available.

Proof of Concept (PoC):

Keycloak fails to properly validate encrypted SAML assertions, allowing for potential tampering by authenticated users. An attacker modifies the assertion structure while maintaining valid cryptographic boundaries recognized by the weak validator. This improper validation allows the attacker to gain unauthorized access or elevate privileges within the SAML session. The issue highlights a flaw in how the system interprets protected assertion components.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: 9Router Host Header Spoofing Access Bypass

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1133, T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

An attacker targets the 9Router management interface which restricts access to local requests only. By spoofing the Host header in an HTTP request, the attacker tricks the application into bypassing local-only verification logic. The request is processed as if it originated from a trusted internal source. This grants the attacker unauthorized access to restricted administrative functionality.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Golang Image PackBits Decompression Resource Exhaustion

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

The golang.org/x/image/tiff library exhibits excessive resource consumption during PackBits decompression. An attacker provides a maliciously crafted TIFF file that triggers infinite or oversized buffer allocation within the decompression function. The application's memory resources are exhausted, leading to a service crash. This constitutes a denial-of-service condition affecting system availability.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-50200

Finding: Steeltoe Env Sanitizer Password Leakage

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The Steeltoe environment sanitizer fails to filter embedded database connection strings within configuration properties. When the application environment information is requested, these strings are returned in cleartext. An attacker queries the environment endpoint to extract these database credentials. These passwords can then be used to gain unauthorized access to backend data stores.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Steeltoe Eureka Registry Poisoning Denial of Service

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

Steeltoe Discovery for Eureka improperly handles unrecognized DataCenterInfo.Name fields in registry data. An attacker submits a crafted registry update that contains an invalid data center name. The client-side registry fetcher crashes upon processing this field, causing a denial of service across the registration service. This prevents legitimate services from discovering each other in the ecosystem.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: SimpleSAMLphp XPath Transformation Denial of Service

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

SimpleSAMLphp processes incoming SAML messages using an XPath transformation engine that is susceptible to complexity-based denial-of-service attacks. An attacker sends a specifically crafted XML payload containing highly nested or redundant XPath queries. The server CPU usage spikes during the processing of these transforms, leading to resource starvation. This results in the inability to process legitimate authentication requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Zebra Address Book Mempool Memory Corruption

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

The Zebra Address Book application encounters an assertion failure due to improper handling of IPv4-mapped network buffers within its mempool manager. An attacker submits malicious network packets that force an unexpected state in the buffer allocation logic. The application triggers an abort/assert, resulting in service termination. This memory corruption poses a risk of stable service degradation under load.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Jxl-Grid 32-bit Platform Integer Overflow

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

No description available.

Proof of Concept (PoC):

The jxl-grid library performs arithmetic operations on 32-bit platforms that are vulnerable to integer overflow. An attacker submits a malformed data payload designed to cause an overflow during size calculation. This leads to an undersized heap buffer allocation and subsequent out-of-bounds writes. The memory corruption can result in arbitrary code execution or service termination.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: SimpleSAMLphp Improper SAML Response Validation

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The SimpleSAMLphp service provider accepts responses from unauthorized identity providers under specific cryptographic conditions. An attacker exploits the combination of an unsigned Response/InResponseTo and a signed assertion missing InResponseTo data. By injecting a spoofed assertion, the attacker forces the application to trust invalid identity data. This allows for session hijacking or unauthorized authentication bypass.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Steeltoe Restricted Actuator Permission Bypass

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official
MITRE ATT&CK: T1068, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

Steeltoe exposes sensitive management actuators, such as heapdump and environment configuration, requiring only basic or restricted permissions. An attacker possessing low-level credentials accesses these endpoints directly. By analyzing the heap or environment data, the attacker obtains sensitive secrets, session tokens, or internal infrastructure details. This leads to significant information disclosure and potential lateral movement.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: Steeltoe Static JWKS Cache Invalidation Failure

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The Steeltoe framework uses a static JWKS cache that is shared across different security schemes and is never invalidated. An attacker with high-level access can poison the global cache, forcing subsequent requests to use

untrusted public keys. Because the cache persists, the impact remains until a full system restart. This results in broad authorization bypass across multiple service instances.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-52792

Finding: Algernon NTFS Filename Script Source Disclosure

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The Algernon server exhibits a behavior on Windows platforms where specific NTFS filename manipulations allow access to server-side script files. An attacker requests the source code of protected script files by appending specialized NTFS syntax to the filename. The server fails to execute the script and instead returns the raw source code to the client. This results in the exposure of sensitive server-side logic and credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50267

Finding: Steeltoe TLS Private Key File Exposure

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

Steeltoe writes TLS private keys to temporary directories with world-readable file permissions. These files are never securely deleted after the application process terminates. A local attacker monitors the temporary directory and retrieves these unencrypted keys. This compromises the confidentiality of all traffic secured by these certificates.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Kiwi TCMS Initialization Page Information Exposure

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 33/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The Kiwi TCMS application fails to disable the /init-db/ initialization endpoint after the initial database setup. An attacker accesses this URI to observe the application's configuration state and environment details. The server responds with diagnostic information which reveals system internals. This data leakage provides reconnaissance material for further exploitation attempts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Steeltoe OAEP Padding Silently Downgrades

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 17/100 | CWE: CWE-256

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

No description available.

Proof of Concept (PoC):

The Steeltoe framework configuration mistakenly ignores user-specified OAEP settings for cryptographic operations. When configured, the library silently falls back to the legacy PKCS#1 v1.5 padding scheme. This downgrade increases susceptibility to adaptive padding attacks on encrypted communications. An attacker with high-level access could perform cryptanalysis to recover sensitive keys from the communication channel.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>